# Sensitive Data Exposure: Exposed Credentials in OWASP Juice Shop

**Severity** : High

## 1. Concept Overview

Sensitive Data Exposure occurs when an application unintentionally reveals confidential information, such as usernames, passwords, API keys, or other credentials.

In this challenge, a developer has accidentally hardcoded valid testing-account credentials in the client-side application code. Since client-side resources are delivered to the browser, users can inspect them and potentially discover the credentials.

## 2. Vulnerability Identification

The application contains hardcoded credentials for an unused testing account.

Although the account is not actively used by the application, its credentials remain valid. This creates a security risk because anyone who discovers them may attempt to authenticate using that account.

## 3. Methodology

Use the steps that actually performed:

1. Opened the OWASP Juice Shop application.
2. Inspected the client-side application resources using browser Developer Tools.
3. Examined the JavaScript source files for hardcoded credentials.
4. Identified the testing-account username and password.
5. Used the discovered credentials to log in to the application.
6. Verified successful authentication and challenge completion on the Score Board.

## 4. Technical Explanation

Hardcoding credentials in client-side JavaScript makes them accessible to anyone who can download or inspect the application's frontend resources.
Example of an insecure implementation:

```
const testAccount = {
   email: "test@example.com",
   password: "TestPassword123"
};
```

This is an illustrative example, not the actual Juice Shop credentials.

## 5. Methodology — Step-by-Step Lab Execution

**Step 1:** Inspect the Client-Side Application

- Opened the OWASP Juice Shop application in the browser.
- Opened Developer Tools using F12.
- Navigated to the Sources tab to inspect the JavaScript files loaded by the application.

**Step 2:** Search for Hardcoded Credentials

- Examined the client-side JavaScript source files.
- Used the search functionality (Ctrl + Shift + F) to search for keywords such as:
    - password

    - email
    - username
    - test
- Identified hardcoded credentials belonging to an unused testing account.

**Step 3:** Analyze the Exposed Credentials

- Inspected the surrounding source code to understand where the credentials were defined.
- Identified the associated testing-account username and password.
- Confirmed that the credentials were present in publicly accessible client-side resources.

**Step 4:** Authenticate Using the Discovered Credentials

- Navigated to the Juice Shop login page.
- Entered the discovered testing-account email and password.
- Submitted the login form.
- Observed that the application successfully authenticated the account.

**Step 5:** Verify Challenge Completion

- Navigated to the OWASP Juice Shop Score Board.
- Verified that the Exposed Credentials challenge was marked as completed.

## 6. Security Impact

- Unauthorized access to the testing account.
- Exposure of account information and application functionality.
- Potential misuse of the account if it has elevated privileges.
- Increased risk of account compromise if the same credentials are reused elsewhere.

## 7. Remediation

- Never hardcode passwords, API secrets, or authentication credentials in client-side code.
- Remove unused testing accounts and revoke their credentials.
- Store sensitive credentials securely on the server side.
- Rotate exposed credentials immediately.
- Apply least-privilege access controls to testing accounts.
- Scan source code and build artifacts for accidentally exposed secrets.

## 8. Result

Successfully completed the Exposed Credentials challenge by discovering valid testing-account credentials in the client-side application resources and using them to authenticate.

## 9. Severity note

**High** is a suggested assessment if the exposed credentials provide access to meaningful account functionality. Actual severity depends on the account's permissions and accessible data. The official Juice Shop difficulty is 2 stars.

## 10. Evidence Screenshots

Include screenshots showing:

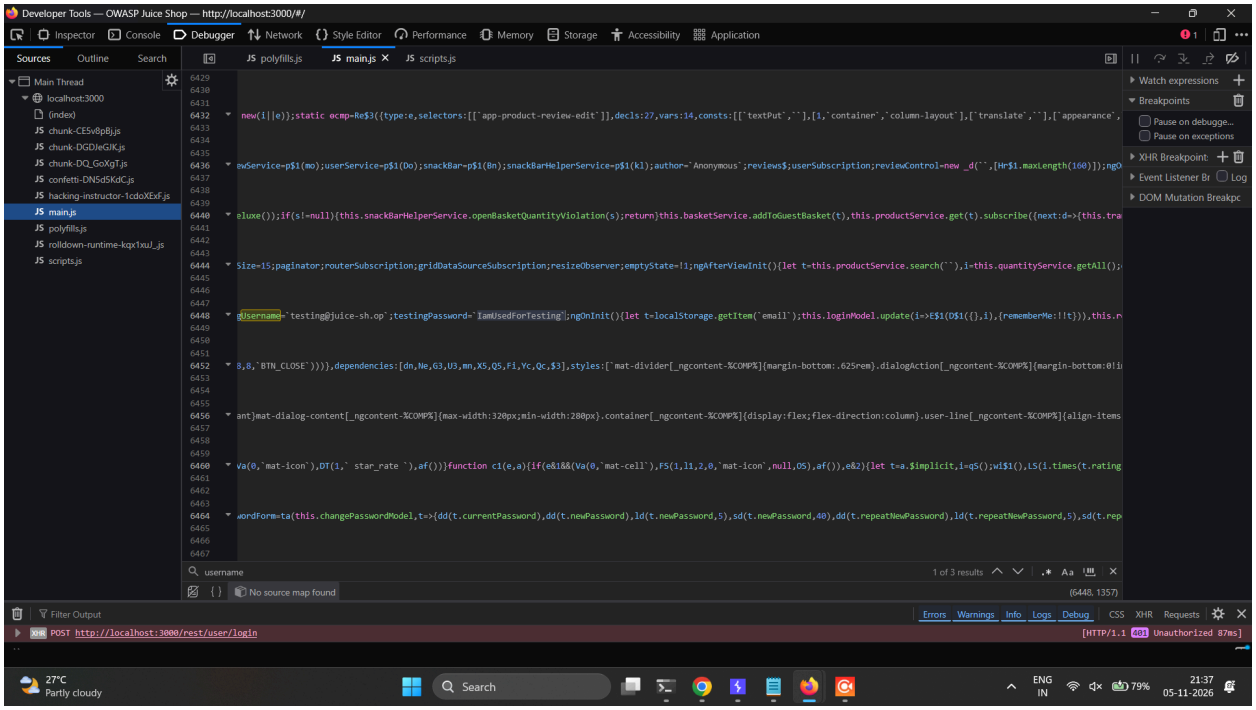



**Fig**: Browser Developer Tools with the relevant JavaScript source the location of the exposed credentials.

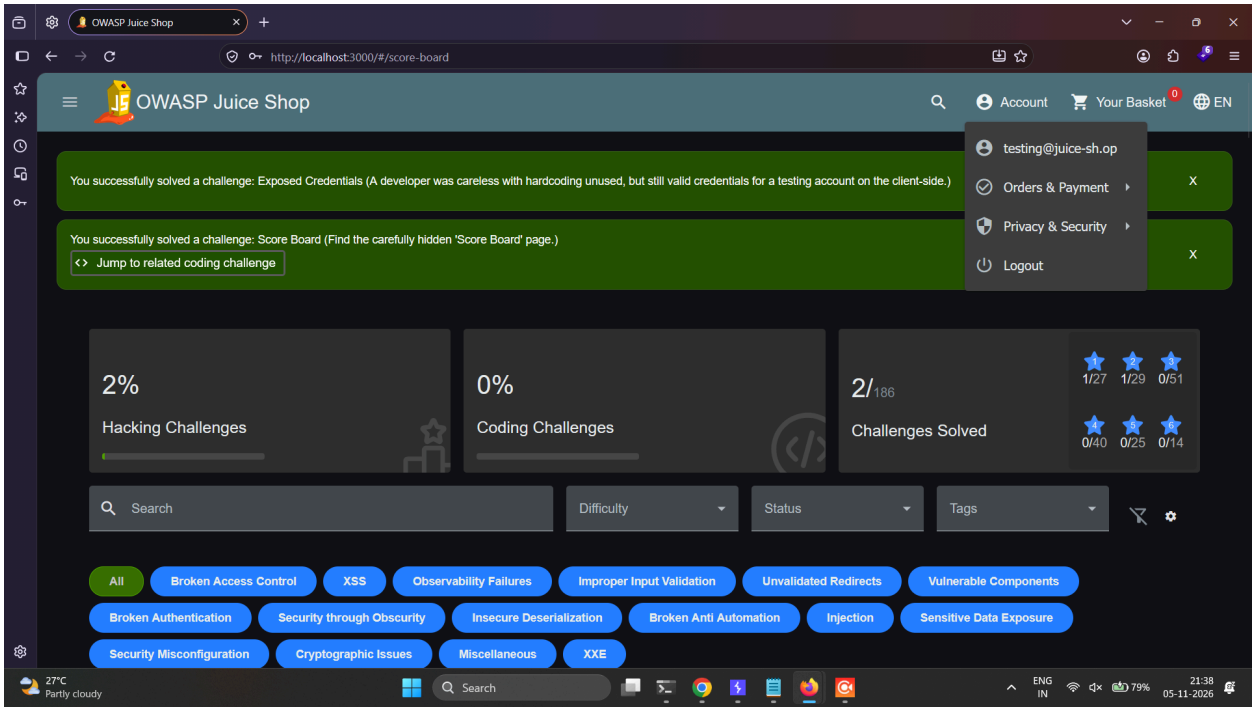



**Fig:** Successful login using the discovered testing account score Board showing the challenge as completed.

## 10. References

- OWASP Juice Shop – Official Companion Guide
- OWASP Secrets Management Cheat Sheet